ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Rockwell FactoryTalk Services Platform (Security / Directory / Linx / AssetCentre) · Component type: **Software Application (SAR) - automation security platform / engineering software** · Target SL = SL 3

Where to work	**FactoryTalk Administration Console (FTAC)** on the **Network Directory** (vs Local Directory): **Users and Groups**, **System › Policies › Security Policy** (password/lockout/SSO), **System › Security › Audit**; **FactoryTalk Diagnostics**; **FactoryTalk Linx** (comms + CIP Security); **FactoryTalk AssetCentre** (central audit/DR). Harden the FT Directory server (Windows).
Ports / paths	FactoryTalk Directory / Services over **RPC/DCOM (TCP 135 + dynamic)**; FactoryTalk Linx CIP **EtherNet/IP 44818 / UDP 2222**; FactoryTalk Activation (FlexNet **TCP 27000/1443**); FactoryTalk Diagnostics; HTTPS for web components. Config/policy stored in the FT Directory; secure it + the host.
Notes	SAR - Rockwell FactoryTalk Services Platform (the security backbone for Studio 5000 / FT View / FT Linx). Prefer the **Network Directory** with a real user model (FactoryTalk accounts or Windows-linked / AD-federated). Password/lockout policy does **not** apply to Windows-linked accounts (enforced by AD). Patch Rockwell PSIRT advisories; keep the FT platform current.
How to read	Each row = native step-by-step (FTAC / policy path) + command-level external-tool steps. Default read-only (read policies/users, capture screenshots). Mark Pass/Fail/Partial/N/A. Auth/injection tools = isolated lab + written authorization.

Project capture & evidence handling - capture the full application backup + exports

Do this BEFORE working the checklist - screenshots of the config and programming screens are not enough on their own. Capture the application's own backup and exports so nothing is missed:
1. Take the native full backup / export first (read-only, before anything): the FactoryTalk application archive (.apa via Application Manager for View SE/ME) and/or the FactoryTalk Directory backup, the FactoryTalk Security (users/roles) export, the RSLinx / FactoryTalk Linx configuration, and the diagnostic logs.
2. Export the security config: users / roles / permissions, authentication / IdP settings, audit configuration, and TLS / certificate settings - as files and screenshots.
3. Collect the logs: application, service / wrapper, audit and event logs (exports), plus running-threads / diagnostics dumps where the product provides them.
4. Capture identity & version: product edition + version / patch level, installed modules / components, and the host OS / runtime (JRE / .NET) - screenshot the About / version screen.
5. Name + protect (keep everything): `<site>_<zone>_<assetTag>_<product>_<version>_<YYYYMMDD-HHMM>_<initials>` with the native backup extension + the exports; SHA-256 hash the backup; store **only** on the encrypted evidence share; the backup usually contains secrets / credentials - **never** email it in cleartext and follow the project retention / classification policy. Do not save admin passwords in tool profiles.
6. Then analyze offsite against the product-specific checklist, the product manuals, vendor research and experience; fill in the tool and auto-generate the report - and remember the manual fields the tool can't auto-write: the **executive-summary narrative**, the **overall assurance level + justification**, and the **punch-list**.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 1.1	Human user identification & auth	Confirm every FactoryTalk-secured app authenticates against the **Network Directory**: in **FTAC › Network › Users and Groups** confirm named users (FactoryTalk or Windows-linked accounts), and that the directory requires logon (not left in an unsecured/single-user state). Set **System › Policies › Security Policy** so authentication is required. **Test:** open a FactoryTalk-secured app (e.g. Studio 5000 / FT View) -> a FactoryTalk logon is required; no anonymous access. **Ext. tools:** FTAC (Users/Groups + Security Policy screenshots); confirm the directory is Network (not Local single-user).	Network Directory enforces per-user logon on all FT apps; no anonymous access.	
SR/CR 1.2	Software process / device identification	Confirm computers/servers are enrolled in the FT Directory (FTAC › **Computers and Groups**) so only registered hosts participate; FactoryTalk Linx device paths are defined; CIP Security binds device comms where enabled. **Ext. tools:** FTAC (Computers list); FactoryTalk Linx (device path review); Wireshark (CIP).	Registered computers only; device comms identified/bound (CIP Security where used).	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 1.3	Account management	In FTAC › Users and Groups apply least privilege: named users/groups, remove/disable defaults (e.g. legacy "All Users"/guest), map roles via groups; where Windows-linked, manage in AD. No shared logins. **Ext. tools:** FTAC (Users/Groups export); AD group review for linked accounts.	Named least-privilege accounts/groups; defaults removed; no shared logins.	
SR/CR 1.4	Identifier management	Confirm unique user identifiers (FTAC / AD) and unique computer identities in the FT Directory; no reuse. **Ext. tools:** FTAC (Users + Computers); AD.	Unique user and computer identifiers; no reuse.	
SR/CR 1.5	Authenticator management	In **System › Policies › Security Policy** set password minimum length, complexity, and expiration for **FactoryTalk accounts** (Windows-linked accounts inherit the **AD** policy - capture that evidence). Change all defaults. **Ext. tools:** FTAC (Security Policy screenshot); AD password policy (gpresult) for linked accounts.	Strong FT password policy (or AD for linked); defaults changed.	
SR 1.6	Wireless access management	**N/A.** Software platform with no wireless interface; wireless is a host/network concern. **Ext. tools:** Confirm no device wireless; host WLAN governed by OS/network.	N/A - justification recorded (software).	N/A
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	
SR/CR 1.8	Public key infrastructure (PKI) certificates	For FactoryTalk Linx **CIP Security** and any HTTPS web components, confirm CA-signed certificates (FactoryTalk System Services CA / enterprise PKI), valid, strong keys; defaults replaced. Secure the FT Directory transport. **Ext. tools:** FactoryTalk Policy Manager / System Services (CA); `openssl s_client -connect <host>:443` for web parts.	CA-signed certs for CIP Security/HTTPS; strong keys; defaults replaced.	
SR/CR 1.9	Strength of public key-based authentication	Confirm public-key authentication uses strong, current keys/algorithms. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of public key-based authentication verified individually.	
SR/CR 1.10	Authenticator feedback	Confirm the FactoryTalk logon dialog and FTAC mask password entry (no cleartext echo). **Ext. tools:** Visual verification at logon.	Authenticators obscured during entry.	
SR/CR 1.11	Unsuccessful login attempts	In **Security Policy** confirm the **account lockout** policy is enabled (Rockwell recommends a max of 3 invalid attempts) for the Network and Local Directory so repeated failures lock the account. **Test:** exceed the lockout threshold (authorized) -> the FT account locks. **Ext. tools:** FTAC (lockout policy); Hydra (ISOLATED, authorized) to confirm lockout engages.	Account lockout enabled and effective (<=3 attempts).	
SR/CR 1.12	System use notification	FactoryTalk has no platform logon banner; enforce the approved use notice on the Windows host (GPO) and in the FT View/HMI client login where used (compensating). **Ext. tools:** Host `gpresult /h gp.html`; FT View client login-banner review.	Use notice at host/HMI (compensating at platform).	Compensating.
SR 1.13	Access via untrusted networks	Confirm the FT Directory server and FT services are reachable only from the trusted OT zone; remote admin via VPN/jump host + MFA; RPC/DCOM and Linx not exposed to untrusted networks. **Test:** from an untrusted VLAN, reach 135/44818 -> must fail. **Ext. tools:** `nmap -Pn -p 135,44818,27000 <host>` from the untrusted side (expect filtered); firewall review.	FT services unreachable from untrusted networks; remote via VPN + MFA.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 2.1	Authorization enforcement	Confirm **FactoryTalk Security** enforces least privilege: in FTAC review **Security** settings on the Network/application (secured **actions** and **resources**, e.g. who may Open/Edit/Download/Configure Security) per user/group. A low-privilege user cannot perform secured actions (e.g. download in Studio 5000). **Test:** as a low-privilege user, attempt a secured action -> denied and audited. **Ext. tools:** FTAC (secured-action/resource matrix); low-privilege negative test.	Least privilege enforced on secured actions/resources; negative test confirms denial.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 2.2	Wireless use control	**N/A.** Software platform, no wireless interface. **Ext. tools:** Confirm no wireless; host/network layer governs.	N/A - justification recorded.	N/A
SR 2.3	Use control for portable/mobile devices	Control the engineering workstations that run FTAC/apps and removable media on the host (OS device-control); only authorized FactoryTalk clients join the directory. **Ext. tools:** Host removable-media GPO; FTAC Computers list (only authorized hosts).	Portable/engineering media controlled; only authorized hosts join.	
SR/SAR 2.4	Mobile code	Control mobile/embedded code: only Rockwell-signed FactoryTalk components/add-ons installed; restrict any scripting (FT View VBA / macros) to trusted, required content; validate installers. **Ext. tools:** Installed-component review; verify installer digital signatures (Rockwell PCDC).	Only signed/required components/scripts; no untrusted code.	SAR-specific.
SR/CR 2.5	Session lock	Confirm FactoryTalk client inactivity handling and the host OS screen lock; FT View clients can be configured to log off/lock on inactivity. **Ext. tools:** Host inactivity-lock GPO; FT View client inactivity config.	Sessions lock/log off on inactivity; re-auth required.	
SR/CR 2.6	Remote session termination	Confirm active FactoryTalk logons can be viewed/terminated and concurrent sessions are bounded/monitored (directory + app session control); remote sessions (RDP) governed at the host. **Ext. tools:** FTAC / app session review; host RDP session control.	Sessions terminable; concurrency bounded/monitored.	
SR/CR 2.7	Concurrent session control	Confirm concurrent sessions are bounded/limited and monitored. **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Concurrent session control verified individually.	
SR/CR 2.8	Auditable events	Enable **FactoryTalk auditing**: **System › Security › Audit** (audit access checks; grants/denies) and route **FactoryTalk Diagnostics** + audit to **FactoryTalk AssetCentre** and the SIEM with the acting user identity. **Test:** make a secured change -> an audit record with user + action + time appears. **Ext. tools:** FTAC (Audit settings); AssetCentre audit view; SIEM ingest of FT Diagnostics.	Security-relevant actions audited with attribution and forwarded.	
SR/CR 2.9	Audit storage capacity	Confirm FactoryTalk Diagnostics/AssetCentre logs are sized/rotated or offloaded to the SIEM, with alerting on collection failure so events are not silently lost. **Ext. tools:** AssetCentre/SIEM retention + source-silent alert review.	Logs sized/offloaded; audit-failure alerting defined.	
SR/CR 2.10	Response to audit processing failures	Confirm a defined response to audit-processing/forwarding failures (alerting; no silent loss). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.9** above (shared steps); confirm this requirement individually and adjudicate it separately.	Response to audit processing failures verified individually.	
SR/CR 2.11	Timestamps	Confirm the FT Directory server + clients are NTP-synced so audit/diagnostic timestamps are accurate and correlate. **Ext. tools:** `w32tm /query /status`; Wireshark `ntp`.	Accurate, synchronized timestamps.	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 3.1	Communication integrity	Protect FT comms: enable **CIP Security** via FactoryTalk Linx for device links; secure the FT Directory/service transport (restrict RPC/DCOM, use IPsec/host firewall between FT nodes); HTTPS on web components; no cleartext credentials on the wire. **Ext. tools:** Wireshark (CIP Security / TLS; no cleartext creds); FactoryTalk Policy Manager.	CIP Security/TLS on FT links; directory transport protected; no cleartext creds.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/SAR 3.2	Protection from malicious code (component)	Confirm software integrity: install only Rockwell-**signed** FactoryTalk components (verify the digital signature / download from Rockwell PCDC); host anti-malware with Rockwell-aware exclusions; restrict install/upgrade to admins. **Ext. tools:** `signtool verify /pa <setup>.exe` (or file Properties › Digital Signatures); host AV; installed-component review.	Signed components validated; install restricted; AV active.	SAR-specific.
SR/CR 3.3	Security functionality verification	After any change re-verify: Network Directory secured, Security Policy (password/lockout), secured-action matrix, Audit settings, CIP Security, and patch level, against the Rockwell hardening baseline; export the FT Directory config. **Ext. tools:** FTAC (settings vs baseline); AssetCentre; `nmap -p 135,44818 <host>`.	Security settings match the hardening baseline after change.	
SR/CR 3.4	Software & information integrity	Protect the FactoryTalk Directory config and application projects (AssetCentre versioning + change detection); restrict who can back up/restore the directory; baseline + hash the config. **Ext. tools:** AssetCentre (versioning/change detection); FT Directory backup integrity.	Directory/project integrity protected; unauthorized change detected.	
SR/CR 3.5	Input validation	Confirm FactoryTalk web/API components validate input; patch known Rockwell PSIRT parsing/RCE issues. **ISOLATED:** test the web/RPC surfaces on a lab instance. **Ext. tools:** Burp/ZAP against web components (ISOLATED); Nessus/OpenVAS for known FT CVEs; PSIRT cross-check.	Inputs validated; known CVEs patched; no injectable path.	
SR/CR 3.6	Deterministic Output	**N/A.** Device does not drive process outputs; deterministic/fail-safe output is not applicable.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 3.7	Error handling	Confirm errors/diagnostics are handled gracefully without leaking sensitive info (no plaintext creds in FT Diagnostics/logs). **Ext. tools:** FactoryTalk Diagnostics review; log content check.	Graceful error handling; no info leak.	
SR/CR 3.8	Session integrity	Confirm FT client/web sessions are integrity-protected (TLS/CIP Security) against replay/hijack; the directory logon is not replayable over cleartext. **Ext. tools:** Wireshark (session inspection).	Sessions integrity-protected; no unauthenticated/cleartext path.	
SR/CR 3.9	Protection of audit information	Protect the FT audit/AssetCentre store and its transport; restrict who can read/clear audit records (least privilege on the audit resource + host ACLs). **Ext. tools:** AssetCentre/DB access review; host ACL on log stores.	Audit records protected from unauthorized read/modify/delete.	

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	
SR/CR 4.2	Information persistence	On decommission/repurpose, remove the FT Directory data, credentials, certificates, exported configs, and backups; confirm no plaintext secrets persist; encrypt the host disk. **Ext. tools:** grep exports for secrets; confirm directory/backups removed; BitLocker status.	Secrets/directory/certs purged on decommission; disk encrypted.	
SR/CR 4.3	Use of cryptography	Confirm modern crypto: CIP Security (TLS/DTLS), HTTPS TLS 1.2/1.3 on web parts, CA-signed certs; disable weak/legacy protocols; the FT Directory transport hardened. **Ext. tools:** `testssl.sh https://<host>`; FactoryTalk Policy Manager (CIP Security policy).	Modern crypto; weak protocols disabled.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 5.1	Network segmentation	Confirm the FT Directory/servers sit in a controlled OT zone behind a firewall; only required FT ports cross (RPC/DCOM tightly scoped, Linx CIP, Activation); no flat convergence with IT; front any remote access with a broker/jump host. **Ext. tools:** `nmap -p 135,44818,2222,27000,1443 <host>` per zone; firewall rule review.	FT platform in a segmented zone; only required flows cross the boundary.	
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	
SR 5.3	General-purpose person-to-person comms restrictions	**N/A.** Automation platform with no general-purpose person-to-person messaging. **Ext. tools:** Confirm no such services.	N/A - justification recorded.	N/A
SR 5.4	Application partitioning	Partition by criticality: separate Network Directories/areas and least-privilege security per application/area; where trust levels differ, separate FT servers/zones. **Ext. tools:** FTAC (area/security segregation); server topology vs criticality.	Applications/areas partitioned by criticality.	

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 6.1	Audit log accessibility	Confirm FactoryTalk Diagnostics/AssetCentre audit is readable/exportable by authorized staff and forwarded to the SIEM; monitor FT service health + the host; passive OT IDS on the segment. **Ext. tools:** AssetCentre export; SIEM; passive OT IDS.	Events accessible/exportable and monitored in near-real-time.	
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 7.1	Denial of service protection	Bound resource use: the FT Directory/services connection limits, host resource limits, and boundary rate-limiting prevent a flood from denying the platform; do not co-host with unrelated apps; monitor host CPU/mem. **Ext. tools:** ISOLATED load/soak test; host resource monitor; service-limit review.	Resources bounded; platform available under load.	
SR/CR 7.2	Resource management	Confirm resource management — resources are bounded; no exhaustion-based loss of function. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Resource management verified individually.	
SR/CR 7.3	Control system backup	Confirm the FT Directory (backup/restore), application projects (AssetCentre), and certificates are backed up (versioned, offline) and a restore is tested on a spare host for a known-good rebuild. **Ext. tools:** FT Directory backup + AssetCentre; restore/validate on a lab host.	Backups current and recovery validated.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / version
SR/CR 7.6	Network & security configuration settings	Harden per the Rockwell guide: install only required FT components, disable unused FT services/features, use the Network (not single-user Local) Directory, scope RPC/DCOM, keep the platform patched, and remove sample/demo content. **Ext. tools:** Installed-feature/services review; `nmap -sTU -p- <host>` (only required open); version vs current.	Least functionality; unused services disabled; patched.	
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	
SR/CR 7.8	Component inventory	Inventory the FactoryTalk components + versions (Services Platform, Security, Linx, AssetCentre, View) and the OS so vulnerabilities track against Rockwell PSIRT / CISA advisories. **Ext. tools:** FT component/version list; Rockwell PSIRT feed; passive OT IDS inventory.	Accurate component/version inventory maintained; advisories tracked.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
FactoryTalk Administration Console (FTAC)	Native security & policy review (all FRs)	Open the Network Directory; Users and Groups; System › Policies › Security Policy (password/lockout/SSO); System › Security › Audit; Computers and Groups; secured-action/resource matrix. Export as the baseline.	Read/authorized admin account.
FactoryTalk Policy Manager / System Services	CIP Security CA & policy (1.8, 3.1, 4.3)	Confirm CA, device enrollment, and the CIP Security policy for FT Linx device links.	Read-only.
FactoryTalk AssetCentre	Central audit, versioning & DR (2.8, 3.4, 6.x, 7.3)	Confirm FT audit/diagnostics are collected, projects versioned, and backup/restore available.	Non-intrusive.
signtool	Signed-component validation (SAR 3.2)	`signtool verify /pa <setup>.exe` or Properties › Digital Signatures; download from Rockwell PCDC.	Read-only.
nmap	Port/service exposure & segmentation (1.13, 5.x, 7.6)	`nmap -p 135,44818,2222,27000,1443 <host>`; scan per zone; confirm RPC/Linx/Activation not exposed to untrusted nets.	Read-only; authorized.
testssl.sh / openssl	TLS on web/CIP Security (1.8, 4.3)	`testssl.sh https://<host>`; confirm TLS1.2/1.3, strong ciphers, CA-signed cert.	Non-intrusive.
Hydra	Account-lockout verification (1.11)	Authorized repeated FT logons to confirm the lockout policy engages.	ISOLATED/authorized only.
Burp / ZAP / Nessus / OpenVAS + Rockwell PSIRT	Web/API validation & CVE scan (3.5, 7.8)	Proxy FT web components to test authz/input (ISOLATED); scan for known FactoryTalk CVEs; cross-check Rockwell PSIRT.	ISOLATED/representative; authorization.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.